

Third-Party Vendor Risk Assessment Report: Notion

Prepared For: Enterprise Security & GRC Review Board

Vendor Evaluated: Notion Labs, Inc.

Assessment Date: September 2026

Target Data Classification: Confidential (Internal collaboration, project tracking, and documentation)

1. Introduction and Scope

This project establishes a standardized, repeatable Third-Party Risk Management (TPRM) workflow designed to evaluate, score, and remediate external vendor security postures. This simulated assessment is applied to Notion Labs, Inc., evaluating its readiness for enterprise deployment within a risk-sensitive environment.

2. Vendor Security Assessment Questionnaire

The following questionnaire evaluates Notion across five core GRC domains using a standard scoring model loosely based on KY3P. (Yes = 2, Partial = 1, No = 0): Total Assessment Score: 47 / 50 (Low Risk Tier)

Domain	Assessment Question	Evidence / Public Documentation	Score
Governance	1. Is there a dedicated Information Security team?	Yes. Dedicated security and privacy teams manage the ISMS.	2
Governance	2. Are employees required to undergo security training?	Yes. Annual and onboarding security awareness training enforced.	2

Governance	3. Are strict NDAs and background checks enforced?	Yes. Standard background screening and binding NDAs for all staff.	2
Governance	4. Are fourth-party vendors held to matching standards?	Yes. Vendor risk management program assesses sub-processors.	2
Governance	5. Are security policies reviewed at least annually?	Yes. Mandatory annual reviews for ISO/SOC compliance.	2
Access Control	6. Is MFA required for internal employee access?	Yes. Phishing-resistant MFA enforced across all internal systems.	2
Access Control	7. Does the platform support SAML 2.0 SSO?	Yes. Enterprise tier fully supports SAML 2.0 and SCIM.	2
Access Control	8. Is internal access based on Least Privilege?	Yes. Role-based access control with regular automated audits.	2
Access Control	9. Are periodic access reviews conducted?	Yes. Quarterly access recertifications for privileged accounts.	2
Access Control	10. Are detailed audit logs available for customers?	Yes. Enterprise workspace audit logs track member actions.	2

Data Protection	11. Is customer data encrypted at rest?	Yes. AES-256 encryption implemented across AWS storage volumes.	2
Data Protection	12. Is data encrypted in transit?	Yes. TLS 1.2 or higher enforced for all incoming/outgoing traffic.	2
Data Protection	13. Is End-to-End Encryption (E2EE) supported?	No. Notion retains keys; true client-side E2EE is unavailable.	0
Data Protection	14. Are automated backups performed daily?	Yes. Automated, encrypted snapshots executed continuously.	2
Data Protection	15. Are cryptographic keys rotated securely?	Yes. Managed through AWS Key Management Service (KMS).	2
Incident Response	16. Is a SIEM system used for security logging?	Yes. Centralized log aggregation and automated alerting in place.	2
Incident Response	17. Are IDS/IPS actively monitoring the network?	Yes. AWS GuardDuty and host-based monitoring deployed.	2
Incident Response	18. Is there a public vulnerability disclosure program?	Yes. Active bug bounty program hosted via HackerOne.	2

Incident Response	19. Is disaster recovery and BCP testing performed?	Yes. Annual DR simulation tests maintaining a 99.9% uptime SLA.	2
Incident Response	20. Is there a strict 48-hour breach notification SLA?	Partial. Incident response plans exist, but standard contracts lack a 48hr window.	1
Compliance	21. Does the vendor hold a SOC 2 Type II report?	Yes. Validated annually by independent third-party CPA firms.	2
Compliance	22. Is the vendor ISO 27001 certified?	Yes. Certified across ISO 27001, 27701, 27017, and 27018.	2
Compliance	23. Can the platform support HIPAA workloads?	Yes. Enterprise tier supports Business Associate Agreements (BAAs).	2
Compliance	24. Is the vendor compliant with GDPR data requests?	Yes. Data Processing Addendum (DPA) fully supports GDPR rights.	2

Compliance	25. Are third-party security audits conducted annually?	Yes. Continuous third-party compliance testing and pen tests.	2
------------	---	---	---

3. Executive Summary

Notion demonstrates a strong information security posture appropriate for enterprise collaboration workloads. Operating on cloud infrastructure (AWS), the vendor maintains industry compliance certifications, including SOC 2 Type II and ISO 27001. They implement necessary cryptographic controls for data at rest (AES-256) and in transit (TLS 1.2+), completed with continuous security event monitoring and a vulnerability management program. However, specific architectural limitations (Lack of Customer-Managed Encryption Keys (CMEK) or native End-to-End Encryption (E2EE)) as well as gaps in public breach notification SLAs require specific mitigating controls before deployment within an environment.

4. Key Vulnerabilities

Lack of E2EE: Because Notion manages the master encryption keys, highly sensitive information (ie. plaintext passwords, regulated PII, or financial account numbers) could be accessed during an infrastructure breach.

Breach Notification SLA: Publicly available documentation does not natively guarantee a strict 48-hour breach notification window, which may conflict with stringent banking regulatory requirements (ie. GLBA or OCC standards).

5. Conditional Approval & Mitigating Controls

Addressing Lack of E2EE: Internal operations must enforce strict data classification policies explicitly prohibiting the storage of regulated non-public personal information (NPI), raw PII, plaintext credentials, or core financial account numbers within Notion workspaces. Usage must be restricted solely to internal process mapping, non-sensitive project documentation, and general collaboration.

Addressing Breach Notification SLA: Legal counsel and procurement must make a formal amendment to the Master Services Agreement (MSA). This amendment must explicitly bind the vendor to a mandatory 48-hour incident and breach notification window to satisfy banking regulatory obligations.